

Name : Akshatha K

Date : 18/06/2024

RANSOMWARE PLAYBOOK

Table of Contents

1. Preface
2. Why is a Ransomware Playbook needed?
3. Overview
4. Roles and Responsibilities
5. Workflow
6. Playbook
 - Developing Investigation Steps with Key Strategies
 - Altering Tactical and Strategic Containment Procedures
 - Designing and Customizing Tactical and Strategic Eradication for the Playbook
 - Adapting Communication Tools and Procedures for Ransomware Incidents
 - Customizing User Actions for Suspected Ransomware
 - Developing Steps for the Help Desk Team to Deal with Ransomware Incidents
7. Appendix
 - Protecting against Ransomware

Effective Date : 18/06/2024

Owner : Akshatha K	Approved By: XYZ
Policy Type : Playbook	Approved Date: DD/MM/YYYY
Initial Reviewed Date: 18/06/2024	Next Review Date: DD/MM/YYYY

Preface

A ransomware playbook is a comprehensive document that provides detailed guidance and procedures for responding to a ransomware attack effectively. It encompasses preparatory measures, response protocols, and recovery strategies to minimise damage, facilitate swift recovery, and ensure compliance with legal and regulatory requirements.

In detail, a ransomware playbook typically includes steps such as:

1. **Preparation:** This involves establishing a robust backup strategy, ensuring critical data is regularly backed up and stored securely offline. It also entails developing an incident response plan (IRP) tailored to ransomware incidents, defining roles and responsibilities of key personnel, and conducting regular training to enhance awareness and readiness among employees. Additionally, it includes implementing monitoring tools to detect ransomware activities early, enabling swift containment and mitigation.
2. **Response and Recovery** The playbook outlines a structured approach to responding to a ransomware attack, starting with immediate isolation of infected systems to prevent further spread. It includes steps for verifying the ransomware variant and assessing the impact on affected systems and data. Procedures for data restoration from secure backups and rebuilding or re-imaging affected systems are detailed, ensuring minimal downtime and business disruption. Communication protocols, both internal and external, are also outlined to keep stakeholders informed throughout the incident response process. Finally, the playbook emphasises the importance of post-incident review and continuous improvement to strengthen defences against future ransomware threats.

Why is a Ransomware Playbook needed ?

A ransomware playbook is crucial because it provides organisations with a structured and systematic approach to responding to ransomware attacks. By outlining detailed procedures, roles, and responsibilities, the playbook ensures that teams can respond promptly and effectively during a crisis, minimising operational disruption, protecting sensitive data, complying with legal requirements, and continuously improving their cybersecurity defences to mitigate the risks posed by ransomware threats.

Overview

Ransomware is a type of malicious software designed to deny access to computer systems or data until a ransom is paid by the victim. It typically encrypts files on the infected system or locks users out entirely, rendering the data inaccessible. Ransomware attacks often involve a ransom demand, usually in cryptocurrency, and may come with threats of data destruction or public exposure if the ransom is not paid within a specified time.

Ransomware spreads through phishing emails, malicious attachments, compromised websites, or exploiting vulnerabilities in software and systems. Once installed, it quickly encrypts files on local drives and network-shared drives, making recovery without the decryption key nearly impossible without backups. Recent ransomware attacks have targeted businesses, healthcare providers, government agencies, and even individuals, causing significant financial losses, operational disruptions, and compromising sensitive data.

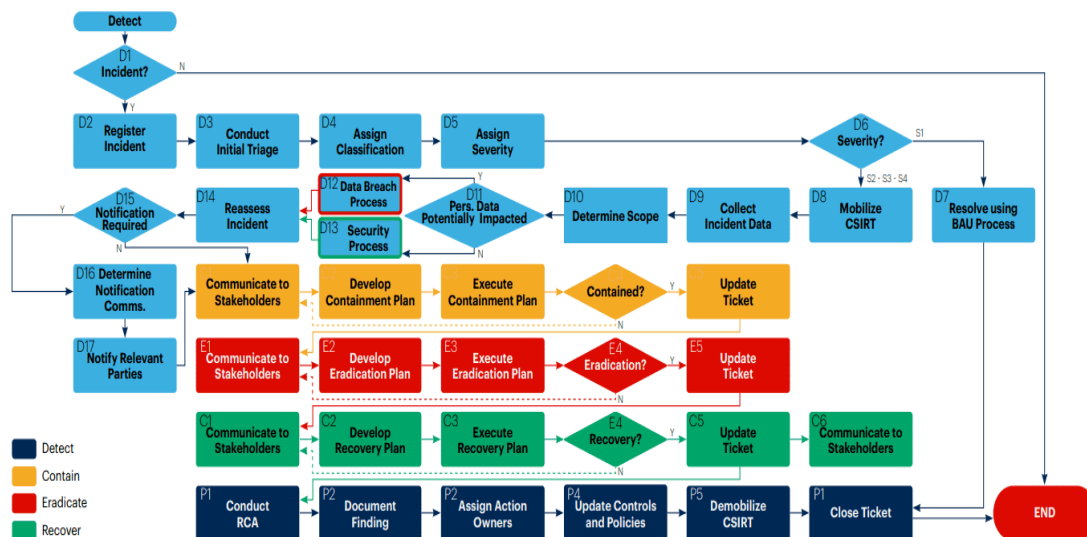
Defence against ransomware involves preventive measures such as regular backups, cybersecurity training to recognize phishing attempts, updating software and systems to patch vulnerabilities, and deploying endpoint protection solutions. In the event of an attack, a swift response is crucial, including isolating affected systems, assessing the impact, and potentially involving law enforcement and cybersecurity experts.

Roles and Responsibilities

1. Incident Response Team Leader: Oversees and coordinates the overall response efforts during the ransomware incident.
2. IT/Security Team: Detects, isolates, and analyses ransomware infections to mitigate further spread and assess impact.
3. Legal and Compliance Officer: Advises on legal implications, coordinates with law enforcement, and manages compliance issues related to the attack.
4. Communications Manager: Manages internal and external communications, including media relations, to maintain transparency and manage reputation.
5. Backup and Recovery Team: Initiates and oversees the restoration of data and systems from secure backups to minimise downtime and data loss.
6. Executive Leadership: Provides strategic direction, approves resources, and communicates with stakeholders to ensure organisational alignment and support.
7. Human Resources: Supports employees with incident-related communications and ensures necessary support services are available.

8. External Consultants or Vendors: Provides specialised technical expertise, assists in negotiations, and advises on post-incident cybersecurity measures.
9. Finance and Accounting: Evaluates financial impacts, manages budgets for response activities, and ensures compliance with financial reporting requirements.
10. Regulatory Compliance Team: Manages regulatory reporting obligations, ensures adherence to data protection laws, and coordinates with regulatory bodies as necessary.

WorkFlow



5

Phase 1: Developing Investigation Steps with Key Strategies

Purpose: To accurately identify the type and scope of the ransomware attack.

Isolation: Immediately isolate affected systems to prevent further spread of ransomware within the network.

Notification: Activate the incident response team and notify key stakeholders, including IT/security teams, legal counsel, and executive leadership.

Identify Ransomware Variant: Conduct malware analysis to determine the specific ransomware variant and its behaviour (e.g., encryption methods, communication protocols).

Indicators of Compromise (IOCs): Identify and document IOCs, such as file extensions, ransom notes, and network traffic patterns associated with the ransomware.

Impact Analysis: Assess the scope and severity of the attack, including the number of affected systems, criticality of encrypted data, and potential operational impacts.

Containment: Implement containment measures to prevent further encryption and damage to systems and data.

Identify the Infection Vector: Determine how the ransomware was delivered (e.g., email attachment, insecure RDP, self-propagation, external drives).

Phase 2: Altering Tactical and Strategic Containment Procedures

Purpose: To quickly contain the ransomware and prevent its spread.

Enhanced Network Segmentation: Implement stricter network segmentation to isolate compromised systems promptly upon detection of ransomware activity.

Behavior-Based Detection: Implement advanced endpoint detection and response (EDR) solutions that use behavioral analytics to detect ransomware activities based on unusual file behavior and process execution patterns.

Endpoint Isolation: Automate endpoint isolation protocols to quickly disconnect compromised devices from the network upon detection of ransomware indicators, preventing further spread.

Encryption Controls: Implement encryption controls to protect sensitive data and prevent unauthorized access in case of ransomware compromise.

Data Loss Prevention (DLP): Deploy DLP solutions to monitor and prevent unauthorized data exfiltration attempts by ransomware.

Block CnC Domains and IPs: Remove phishing emails and ensure endpoint protection is updated.

Deploy Custom Signatures: Build and deploy signatures based on IOCs.

Implement Automated Containment: Use SOAR for automated containment measures.

Phase 3: Designing and Customizing Tactical and Strategic Eradication for the Playbook

Purpose: To remove ransomware from infected systems and ensure no reinfection.

Real-Time Threat Detection: Implement continuous monitoring of network and endpoint activities using threat intelligence feeds and anomaly detection to detect and respond to ransomware incidents promptly.

Incident Response Drills: Conduct regular incident response drills and simulations to test the effectiveness of eradication procedures and improve team readiness.

Vulnerability Remediation: Address underlying vulnerabilities that allow ransomware to infiltrate the network and encrypt data.

Backup Restoration: Restore data from verified, clean backups that were not affected by the ransomware attack.

Data Verification: Verify the integrity and completeness of restored data to ensure no residual ransomware artifacts remain.

Malware Analysis: Conduct in-depth analysis to identify the specific ransomware variant, its behavior, and encryption techniques used.

Phase 4: Adapting Communication Tools and Procedures for Ransomware Incidents

Purpose: To maintain clear and consistent communication throughout the incident.

Prepared Response Templates: Develop predefined templates for internal and external communications to expedite response and ensure consistency in messaging.

Incident Notification System: Implement an automated incident notification system to alert key stakeholders (e.g., incident response team, executive leadership, IT/security teams) immediately upon detection of a ransomware incident.

Utilise tools like email alerts, SMS notifications, and dedicated incident response platforms to ensure rapid communication and coordination.

Crisis Communication Training: Provide crisis communication training to designated spokespersons and incident response team members to effectively manage communications during high-stress situations.

Post-Incident Analysis: Conduct a post-incident review of communication effectiveness and identify areas for improvement in communication tools, procedures, and response strategies.

Public Relations Management Tools: Monitor social media and news platforms for any mentions or discussions related to the ransomware incident to manage public perception and respond promptly.

Legal and Regulatory Compliance: Ensure all communication adheres to legal and regulatory requirements, including data breach notification laws and industry-specific regulations.

Consult with legal counsel to review and approve external communications, particularly regarding sensitive information and potential ransom payment considerations.

Phase 5: Customising User Actions for Suspected Ransomware

Purpose: To ensure users take the correct actions when they suspect ransomware.

User Awareness: Educate users on recognizing ransomware symptoms, such as unusual pop-up messages, file encryption notifications, or sudden system slowdowns.

Incident Reporting: Instruct users to report any suspicious activity immediately to the IT or security team through designated channels (e.g., helpdesk, incident response hotline).

Segregate System from Network: Disconnect or logically segregate the infected system.

Document Observations: Take pictures of ransom messages and document details such as observations, actions taken, and network details.

Phase 6: Developing Steps for the Help Desk Team to Deal with Ransomware Incidents

Purpose: To equip the help desk team with procedures to handle ransomware reports.

Create Incident Ticket: Capture all relevant details from the user and update the incident ticket.

Detailed Logging: Document incident details thoroughly in the help desk ticketing system, including timestamps, symptoms reported by the user, and any initial troubleshooting steps taken.

Severity Assessment: Assess the severity of the incident based on impact to the user and potential risk of spreading across the network.

Guided Steps: Provide step-by-step instructions or runbooks for help desk staff to assist users with restoring from backups, running antivirus scans, or disconnecting infected devices from the network.

Monitoring and Feedback: Monitor ongoing system activities and user feedback following ransomware incidents to ensure full recovery and address any residual issues.

Documentation and Lessons Learned: Document lessons learned from each ransomware incident handled by the help desk to improve response procedures and enhance future incident response readiness.

Protecting Against Ransomware

- Regularly backup all important data and ensure backups are stored offline or in a separate, secure location. This ensures you can restore your data without paying ransom if attacked.
- Maintain up-to-date operating systems, software, and applications. Software updates often include patches for security vulnerabilities that attackers exploit.
- Install reputable antivirus and anti-malware software on all devices. Keep these programs updated and conduct regular scans to detect and remove malicious software.
- Exercise caution when opening email attachments or clicking on links, especially from unknown or suspicious senders. Be wary of unexpected emails requesting urgent action.
- Use Strong Passwords and Multi-Factor Authentication (MFA)
- Implement the principle of least privilege (PoLP) by restricting user permissions to only what is necessary for their roles. This limits the spread of ransomware in case one account is compromised.
- Provide regular training and awareness programs for employees or family members about ransomware threats, phishing attacks, and safe computing practices.
- Use intrusion detection and prevention systems (IDS/IPS) to monitor network traffic for suspicious activity and block threats before they cause harm.
- Develop and maintain an incident response plan that outlines procedures for responding to a ransomware attack. Ensure all stakeholders know their roles and responsibilities in case of an incident.
- Regularly test and update your incident response plan through simulated exercises or tabletop drills to ensure it remains effective and relevant.
- Evaluate and deploy specialised ransomware protection tools that can detect and respond to ransomware attacks, such as behaviour-based detection or ransomware-specific backup solutions.